IT Security and Acceptable Use Policy

Document type: policy

Category: it_security

Effective date: 2026-01-15

Version: 5.1

Owner: Information Security Team, Acme Analytics Pvt Ltd

Note: Fictional sample document created for testing a RAG system. Acme Analytics Pvt Ltd is not a real company.

1. Purpose and scope

1.1 This policy protects the information and systems of Acme Analytics Pvt Ltd and its clients. It applies to every employee, intern, consultant and vendor who uses an Acme device, network, account or data.

1.2 Breaking this policy can lead to disciplinary action under the Code of Conduct.

2. Accounts and passwords

2.1 Every account must be protected with multi-factor authentication (MFA). MFA is enforced for email, VPN, code repositories and cloud consoles.

2.2 Passwords must be at least 12 characters long and unique to each account. Passwords are not changed on a fixed schedule, but must be changed immediately if you suspect they are compromised.

2.3 Use the company-provided password manager. Never share your password or MFA code with anyone, including IT staff. IT will never ask you for it.

2.4 Shared or generic accounts are not allowed except for approved system accounts.

3. Devices

3.1 Work must be done only on company laptops, which are encrypted with BitLocker or FileVault, and managed by IT.

3.2 The screen must lock automatically after 5 minutes of inactivity, and must be locked manually whenever you leave your desk.

3.3 Do not install software yourself. Request it from the approved software catalogue. Pirated software is strictly prohibited.

3.4 Use of personal USB drives and external hard disks is blocked. If there is a genuine need, raise a request with the IT helpdesk.

3.5 Personal mobile phones may be used for email and chat only after installing the company mobile device management (MDM) application. The company can remotely wipe only the company data in the app.

3.6 If a device is lost or stolen, report it to security@acme-analytics.example and the IT helpdesk within 2 hours of discovering the loss.

4. Data classification and handling

Class	Examples	Rules
Public	Website content, published blog posts	No restriction

Class	Examples	Rules
Internal	Policies, org charts, internal announcements	Share only within Acme
Confidential	Client data, source code, financial results, employee records	Share only on a need-to-know basis, on approved tools; encrypt when sending outside
Restricted	Customer personal data, passwords, keys, unreleased financials	Access by named people only; never on personal devices, email or chat

4.2 Do not store company data on personal cloud storage, personal email or messaging apps.

4.3 Do not forward company email to a personal email address.

5. Network and remote access

5.1 The company VPN must be on whenever you are not in an Acme office.

5.2 Public Wi-Fi may be used only with the VPN switched on.

5.3 Do not connect personal devices to the office wired network. A guest network is available for personal devices.

6. Email, phishing and social engineering

6.1 Be careful with links and attachments from unknown senders. Use the "Report phishing" button in the email client to report a suspicious email.

6.2 Phishing simulations are run every quarter. An employee who fails three simulations in a year must repeat the awareness training.

6.3 Verify any request to change bank details or to make an urgent payment, by calling the person on a known number.

7. Use of AI tools

7.1 Employees may use only the AI assistants that are approved by the Information Security Team and listed on the intranet.

7.2 Do not enter Confidential or Restricted data, including client data, source code and personal data, into public AI tools or chatbots.

7.3 AI-generated content, including code, must be reviewed by a human before it is used in client work or in production.

8. Incident reporting

8.1 Report any suspected security incident immediately to security@acme-analytics.example or on the 24-hour security line +91-40-5550-0199. Do not try to investigate it yourself.

8.2 Examples of incidents: a lost device, a phishing link that was clicked, malware, unauthorised access, data sent to a wrong person.

8.3 Incident severity and response targets are in the table below.

Severity	Description	First response target
Critical	Confirmed data breach, ransomware, or loss of client data	30 minutes
High	Compromised account, lost device with data	2 hours

Severity	Description	First response target
Medium	Phishing click with no sign of compromise	8 hours
Low	Policy violation without impact	2 working days

9. Monitoring

Acme monitors the use of its systems, networks and devices to protect the company, as allowed by law. Employees should not expect privacy for personal use on company devices.

10. Leaving the company

Access to all systems is removed at 6:00 PM on the last working day. The employee must return all devices, and must delete any company data stored anywhere else.

11. Physical security

Wear your ID card in the office. Do not allow tailgating through the access doors. Visitors must register at the reception, wear a visitor badge and be accompanied at all times. Keep desks clear of confidential papers at the end of the day (clean desk).